

Veille sécurité

Date de rédaction : 2026-07-10. Toutes les sources citées ont été consultées ce jour-là (les URLs et les faits relevés datent de cette consultation).

Méthode de veille

- **Sources** : OWASP Top 10 (référentiel des risques) et OWASP Cheat Sheet Series (recommandations opérationnelles par sujet), complétées par les notes de version des dépendances de sécurité (`helmet` , `bcryptjs` , `express-rate-limit`) lors des mises à jour npm.
- **Fréquence** : à chaque nouveau lot touchant une surface sensible (authentification, uploads, sessions, données personnelles), plus une passe complète lors des revues de code transverses.
- **Tri** : une menace n'entre dans le projet que si elle concerne notre surface réelle (pas d'API publique JSON ouverte, pas de paiement) ; chaque décision est appliquée dans le code ET couverte par une assertion de test.

Référentiel : **OWASP Top 10 — édition 2025** (consultée le 2026-07-10 : <https://owasp.org/Top10/2025/>). Les codes A0x:2025 ci-dessous s'y réfèrent.

Fiches menace → décision → preuve

1. Injection (A05:2025 — Injection)

- **Source** : <https://owasp.org/Top10/2025/> (2026-07-10).
- **Impact ici** : recherche publique, formulaires, IDs d'URL.
- **Décision** : toutes les requêtes passent par Prisma (requêtes paramétrées, jamais de SQL concaténé) ; validation serveur systématique (`src/validators/` , six validateurs : formats, listes autorisées, longueurs) ; IDs d'URL validés (`src/utls/http.js`).
- **Preuve** : `src/services/*.js` (aucun `$queryRaw`), `test/correctifs.cjs` (longueurs, formats), `test/smoke.cjs` .

2. XSS — injection dans les pages et les emails

- **Source** : OWASP Top 10 2025 (A05) et pratique Twig (2026-07-10).
- **Impact ici** : titres/descriptions d'annonces, noms de candidats, affichés aux écoles et dans les emails.
- **Décision** : autoescape Twig sur toutes les vues ; CSP stricte `script-src 'self'` (aucun script inline, données via blocs `application/json` échappés — seuls usages `|raw` documentés : `#map-data` et `#stats-data`) ; `esc()` sur tout texte utilisateur interpolé dans les emails HTML.
- **Preuve** : `src/app.js` (helmet + commentaire `|raw`), `src/services/mailler.js` (`esc`), `test/smoke.cjs` (« en-tête Content-Security-Policy présent et strict »), `test/lot-b.cjs` (« `esc()` échappe le HTML »), `test/lot-h.cjs` (« aucune insertion HTML »).

3. CSRF

- **Source** : OWASP CSRF Prevention Cheat Sheet — synchronizer token pattern recommandé pour les applications à session (<https://cheatsheetseries.owasp.org/cheatsheets/Cross->

Site_Request_Forgery_Prevention_Cheat_Sheet.html, 2026-07-10).

- **Impact ici** : tous les POST (annonces, candidatures, contrats, admin).
- **Décision** : jeton de session vérifié globalement (`src/middlewares/csrf.js` , comparaison `timingSafeEqual`) ; les routes multipart vérifient le jeton APRÈS multer (`verifyAfterUpload`) avec nettoyage des fichiers déjà téléversés si le jeton est invalide ; jamais de jeton en query string.
- **Preuve** : `test/correctifs.cjs` (6 assertions CSRF, dont fichiers supprimés sur jeton invalide), `test/smoke.cjs` (403 sans jeton), `test/ameliorations-v2.cjs` (page d'erreur CSRF dédiée).

4. Uploads malveillants

- **Source** : OWASP File Upload Cheat Sheet — valider les magic bytes en plus du Content-Type, stocker hors du répertoire web (https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html, 2026-07-10).
- **Impact ici** : 4 pièces de candidature + images de signature.
- **Décision** : vérification du MIME déclaré ET des magic bytes réels (`src/middlewares/upload.js`), taille maximale, noms de fichiers régénérés côté serveur, stockage privé sous `storage/` (jamais `public/`), accès uniquement via des routes protégées scopées par école ; signatures PNG validées par contenu et limitées à 200 Ko (`src/services/signatureImage.js`).
- **Preuve** : `test/ameliorations.cjs` (PNG déguisé en PDF → 400 + fichier supprimé), `test/smoke.cjs` (aucun fichier sensible sous `public/` , cloisonnement école B → 404), `test/lot-g.cjs` (magic bytes signature).

5. Force brute et énumération de comptes (A07:2025 — Authentication Failures)

- **Source** : OWASP Top 10 2025 (2026-07-10).
- **Impact ici** : connexion école/admin, mot de passe oublié, inscription.
- **Décision** : `express-rate-limit` sur les routes sensibles (connexion, inscription, candidature, abonnement alertes, signature, relais API) ; réponses neutres (« si le compte existe, un email a été envoyé ») ; hachage factice à la connexion admin pour un temps de réponse constant ; jetons email/reset hachés en base et à expiration.
- **Preuve** : `src/routes/*.js` (limiteurs), `test/lot-i.cjs` (rate-limit 30/min/IP), `test/correctifs.cjs` , `test/ameliorations-v2.cjs` (reset).

6. Sessions (A01:2025 — Broken Access Control / A07)

- **Source** : OWASP Session Management Cheat Sheet (https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html, 2026-07-10).
- **Impact ici** : espaces école et admin.
- **Décision** : régénération de session à chaque connexion (anti-fixation — rend aussi impossible une session mixte école+admin) ; cookies HTTP-only, `sameSite=lax` , `secure` en production ; sessions persistées en base (révocables) ; les sessions ouvertes ailleurs sont détruites après une réinitialisation de mot de passe ; ouvrir un lien de suivi candidat neutralise la session back-office du navigateur (anti-usurpation).
- **Preuve** : `test/ameliorations-v2.cjs` (« cloisonnement », invalidation après reset), `test/lot-g.cjs` (suivi neutralise la session école), `src/services/sessionService.js` .

7. Stockage des mots de passe (A04:2025 — Cryptographic Failures)

- **Source** : OWASP Password Storage Cheat Sheet — Argon2id recommandé en premier choix, bcrypt accepté avec un facteur de travail ≥ 10 et une limite d'entrée de 72 octets

(https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html, 2026-07-10).

- **Impact ici** : comptes écoles et admins.
- **Décision** : bcrypt (facteur 10) avec limite de longueur compatible 72 octets appliquée par les validateurs.
Honnêteté de veille : OWASP privilégie désormais Argon2id pour les nouveaux systèmes — migration possible sans casse (re-hachage à la prochaine connexion), notée pour le chantier production.
- **Preuve** : `src/utils/password.js` , `src/validators/schoolValidator.js` (longueur max), `test/correctifs.cjs` .

8. Données personnelles et conformité (RGPD)

- **Source** : registre des exigences du cahier des charges v1 + CNIL (principes de minimisation et de durée de conservation).
- **Impact ici** : pièces d'identité, CV, emails de candidats et d'abonnés.
- **Décision** : minimisation (la page publique de suivi n'expose aucune donnée personnelle du candidat) ; purge automatique journalisée — alertes jamais confirmées après 7 jours, candidatures refusées et leurs fichiers après 180 jours, jetons expirés ; double opt-in des alertes et désabonnement avec suppression réelle de la ligne.
- **Preuve** : `test/lot-b.cjs` (« ne fuit pas l'email »), `test/lot-j.cjs` (24 assertions purge), `test/lot-i.cjs` (désabonnement RGPD), modèle `PurgeRun` (journal affiché sur `/admin`).

Synthèse pour le jury

Huit familles de menaces suivies, chacune tracée de la source à l'assertion de test. Le point de vigilance issu de la veille du 2026-07-10 : l'édition 2025 du Top 10 (sortie récente) élève la chaîne d'approvisionnement logicielle (A03) — réponse actuelle : dépendances npm en nombre restreint, `npm audit` lors des installations, versions verrouillées par `package-lock.json` ; et le stockage des mots de passe pourra migrer vers Argon2id au passage en production.